WI-FI SECURITY ASSESSMENT REPORT

Lab-Based Security Assessment of a (Personal MTN) MiFi Device

Cybersecurity Programme

Prepared by: Awe Oluwasanmi Mayokun
Cybersecurity Professional, Penetration Tester
GitHub: https://github.com/CyberAce001

Target: MTN MiFi (wireless-only)
Test Platform: Kali Linux (VMware Workstation, bridged network) on a Windows host

Date: 21st August, 2026

1. Executive Summary

This report documents a lab-based Wi-Fi security assessment of a personally owned MTN MiFi device, carried out from a Kali Linux virtual machine bridged onto the target network. The assessment combined network scanning (Nmap), web application testing (OWASP ZAP), and traffic analysis (Wireshark) against the device's admin interface and network services, following a scope limited strictly to devices owned by the assessor.

The assessment identified one Critical finding (default administrative credentials in active use), two High findings (WPS enabled; an outdated, vulnerable JavaScript library — Underscore.js 1.3.1 — loaded by the admin interface and flagged by ZAP), and several Medium and Low–Medium findings relating to an HTTP-only admin interface, an outdated DNS resolver (dnsmasq) within a publicly disclosed vulnerability range, an unauthenticated information-disclosure page, and a heuristic denial-of-service flag. Encouragingly, several controls were already correctly configured — WPA2-PSK (AES) encryption, UPnP disabled, and an account-lockout mechanism on the admin login — and are documented in Section 5 as positive observations.

A distinguishing factor of this assessment is that the primary structural weakness — the admin interface being served over plain HTTP with no option to enforce HTTPS — can be attributed to a firmware-level limitation of this device model, which unfortunately has no available upgrade path as confirmed by vendor. This shifts the practical remediation from a simple configuration change to a set of compensating controls, detailed in Section 6. A second distinguishing factor is that manual packet-level verification of the login flow (Section 4.5) went beyond what the automated tools reported, uncovering that the admin password is hashed client-side with a per-attempt varying value rather than transmitted as raw plaintext — a partial mitigation that does not substitute for the missing TLS, but which a less careful assessment could easily have overstated or missed.

2. Scope & Methodology

2.1 Objective

Assess the Wi-Fi and network security posture of a personally owned MTN MiFi device in a controlled lab environment, and produce an assessment report, remediation/hardening recommendations, and a short walkthrough video (per project brief CS-12: “Wi-Fi Security Assessment”).

2.2 Authorization & Scope

Testing was restricted to hardware owned by the assessor: an MTN MiFi (wireless-only, no USB/Ethernet port). No third-party or production networks were tested at any point.

2.3 Test Environment

Kali Linux was run as a virtual machine under VMware Workstation on a Windows host, with the VM's network adapter set to Bridged so it received its own IP address on the target Wi-Fi subnet. VMware was used in preference to VirtualBox because it was already installed on the host machine; running two hypervisors side by side was assessed as impractical given expected performance impact on the host.

Bridged mode was a deliberate methodology choice, not the default left in place. NAT was considered and rejected: under NAT the VM would sit behind VMware's own internal virtual subnet and share the host's single address when reaching the MiFi, meaning it would never appear as its own distinct, directly reachable peer on the target network — undermining the premise that the VM is scanned and connects to the MiFi as an independent device. Bridged mode was required for the VM to obtain its own IP address on the MiFi's own subnet, consistent with Section 3.1's topology.

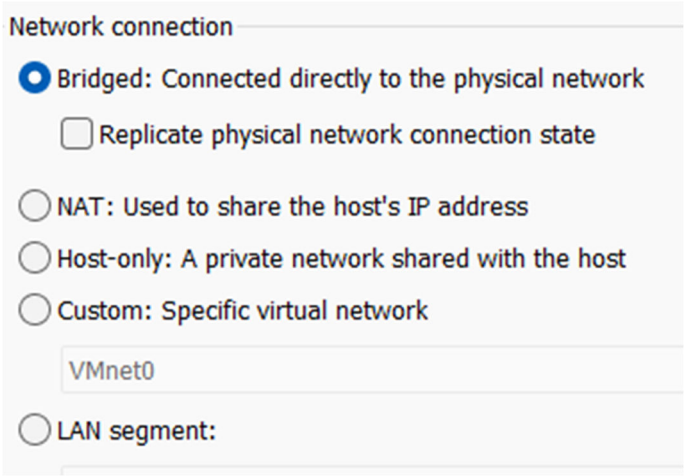


Figure 1: VMware Workstation network adapter set to Bridged for the Kali VM

Tools used: Nmap, OWASP ZAP (Community Edition, add-ons kept on the Release update channel and checksum-verified via ZAP's official marketplace), Wireshark, and the MiFi's own built-in device-manager web interface, which was discovered during testing to expose a number of additional security-relevant settings beyond the basic status page.

2.4 Methodology Phases

- Reconnaissance: SSID, encryption type, channel, connected-client count, and device model/firmware captured from the MiFi's own interface.
- Network scanning: Nmap host discovery and service/version/vulnerability scanning (-sV, -sC, --script vuln, and a full 65535-port sweep with -p-) against the MiFi, the host machine, and the Kali VM itself.

- Web application testing: OWASP ZAP Spider (unauthenticated and authenticated passes) and passive/manual analysis of the MiFi's web admin interface, including ZAP's passive Retire.js check for outdated JavaScript components.
- Traffic analysis: Wireshark capture of session traffic, including manual inspection of the login POST request's form fields, to check for credential exposure and general traffic patterns.
- Findings consolidation, risk rating, and remediation planning (this report).

2.5 Methodology Notes & Limitations

- Bridged-VM wireless association: the Kali VM and the host machine were assigned distinct MAC addresses and IP leases, but the MiFi's own connected-device count showed only one associated wireless client. This is a known characteristic of bridging a VM over Wi-Fi (rather than Ethernet) on Windows — 802.11 association happens once, at the host's physical adapter, while the VM's separate IP is handled by VMware below that layer. This did not affect the validity of Nmap, ZAP, or Wireshark results, which operate above the wireless association layer.
- Login lockout behaviour: running the ZAP Spider with “Process Forms” and “POST Forms” enabled (Figure 2) caused it to auto-submit the admin login form with dummy values while crawling, exhausting the login-attempt counter from the Kali VM. Testing showed this lockout is tracked independently per source IP — the host machine's browser (a different IP on the bridged subnet) was able to log in successfully at the same time the VM remained locked out — even after a waiting time of roughly 20+ minutes until after a device reboot. This is recorded both as a methodology caveat and as a positive finding (Section 5); Process Forms/POST Forms were subsequently disabled ahead of further crawling near the login page.
- Proxy performance impact: browsing through ZAP's proxy was observed to measurably reduce connectivity/responsiveness compared to browsing directly, most noticeably from the Kali VM. This was accounted for when timing scans and is noted here for anyone reproducing this methodology.

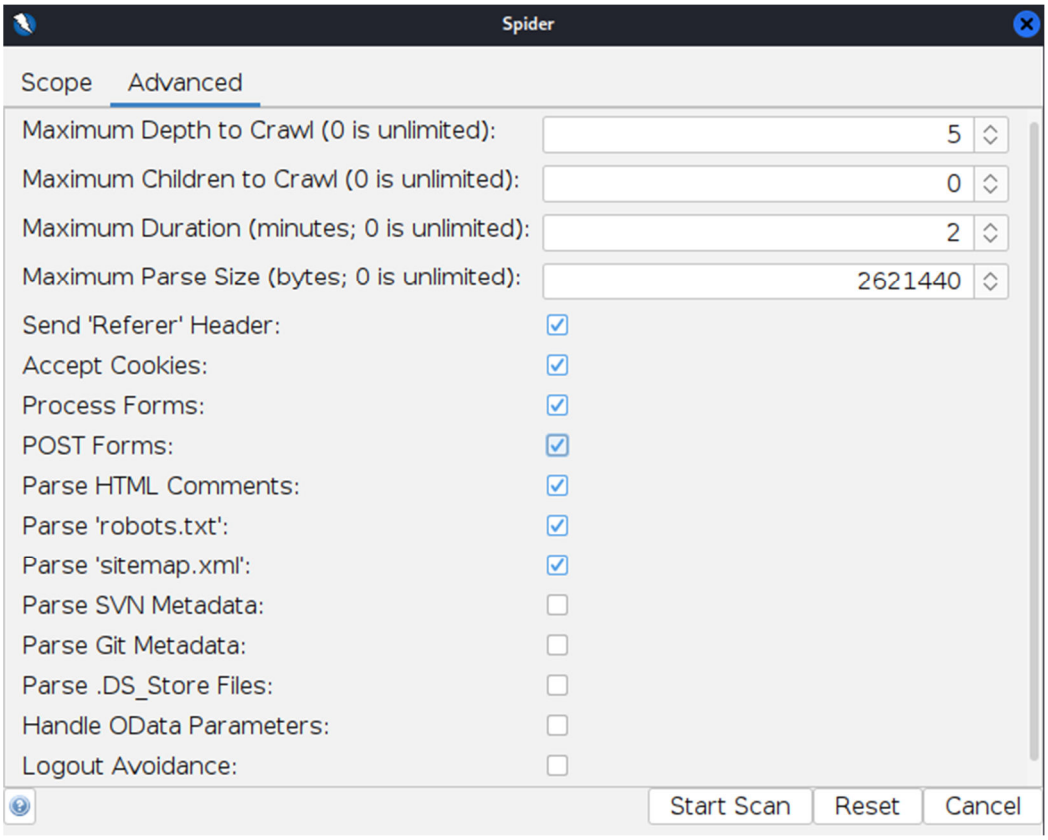


Figure 2: ZAP Spider Advanced options — Process Forms and POST Forms enabled during the crawl that triggered the login lockout

3. Lab Environment Description

3.1 Topology

The diagram below shows the physical/logical layout used for all testing in this report: the target MiFi, the Windows host associating to it over Wi-Fi, and the Kali VM bridged onto that same connection with its own IP address.

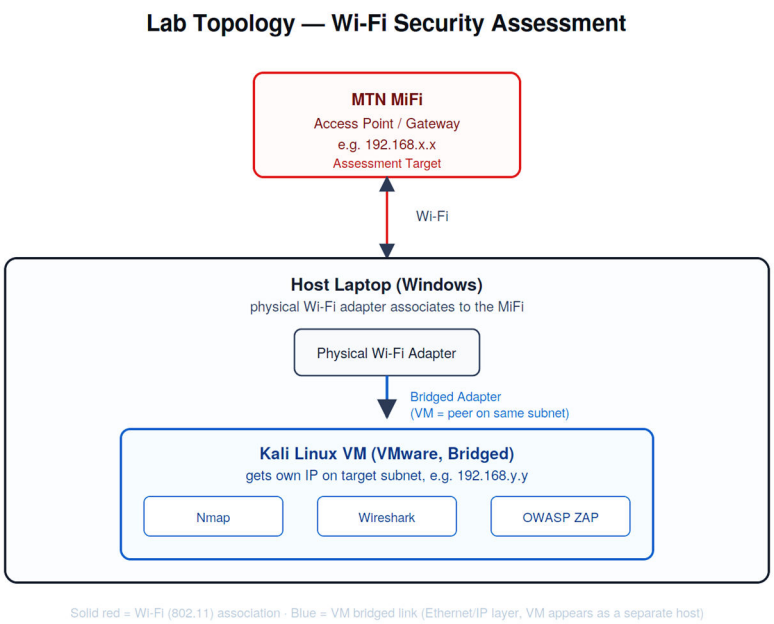


Figure 3: Lab topology — MiFi, host machine, and bridged Kali VM

3.2 Snapshot Reference

A clean VMware snapshot of the Kali VM was taken immediately after initial setup and tool updates, before any target-facing testing began. This snapshot serves as the reproducible baseline for this assessment and as safe-lab evidence that testing was conducted from a controlled, disposable environment.

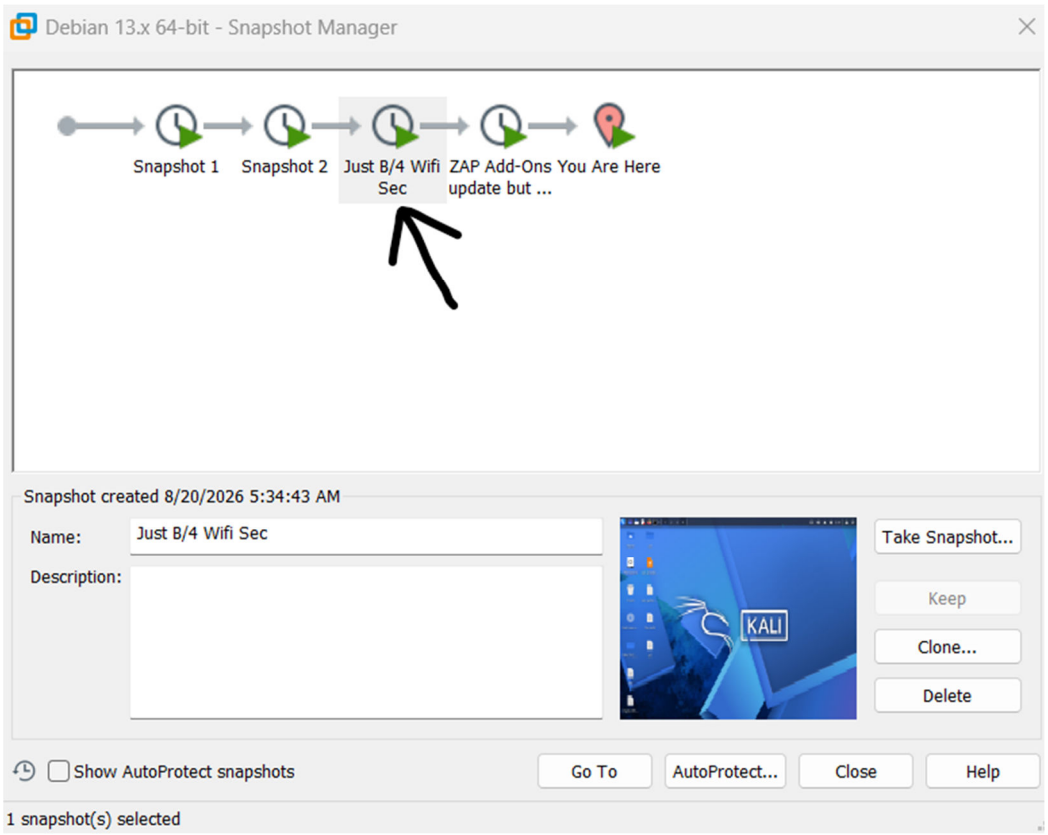


Figure 4: VMware Snapshot Manager showing the pre-test baseline snapshot

4. Findings & Risk Rating

Findings are listed in priority order. Risk ratings follow a standard Critical / High / Medium / Low scale, reflecting likelihood and impact given the device's role as a personal, non-enterprise access point.

Finding	Evidence	Risk	Recommendation
Default admin credentials work	*Fig. 5 (login)*	**Critical**	Change the default admin password immediately
WPS enabled	*Fig. 6 (device manager)*	**High**	Disable WPS in MiFi settings
Outdated/vulnerable JavaScript library — Underscore.js 1.3.1 (CWE-1395)	*Fig. 7 (ZAP alert)*	**High**	Update the bundled library to a current, patched release
dnsmasq 2.80 in DNSpooq-affected range (CVE-2020-25681–25687)	*Fig. 8 / Evidence 1 (Nmap)*	**Medium–High**	Update firmware if a fix ever ships; not currently possible on this model (see Finding 5)

Finding	Evidence	Risk	Recommendation
Admin interface served over HTTP only; HTTPS not offered by this firmware	*Fig. 9–10 (address bar / Wireshark)*	**Medium**	No firmware upgrade path (MTN-confirmed); current firmware offers no HTTPS option — apply compensating controls (below)
Unauthenticated status page discloses connected devices and battery level	*Fig. 11*	**Low–Medium**	Accept as a platform limitation; keep device off untrusted networks
Slowloris DoS heuristic flag (CVE-2007-6750)	*Evidence 2 (Nmap --script vuln)*	**Medium (heuristic, unconfirmed)**	Monitor; do not actively DoS-test a single production device

4.1 Finding 1 — Default Administrative Credentials (Critical)

During initial reconnaissance, the MiFi's admin web interface was found to be accessible using the manufacturer's default username and password. Default credentials are the single most common root cause of home-router compromise, since they are publicly documented and require no technical skill to exploit — any device on the Wi-Fi network (or, combined with Finding 5, anyone able to observe network traffic) could gain full administrative control.

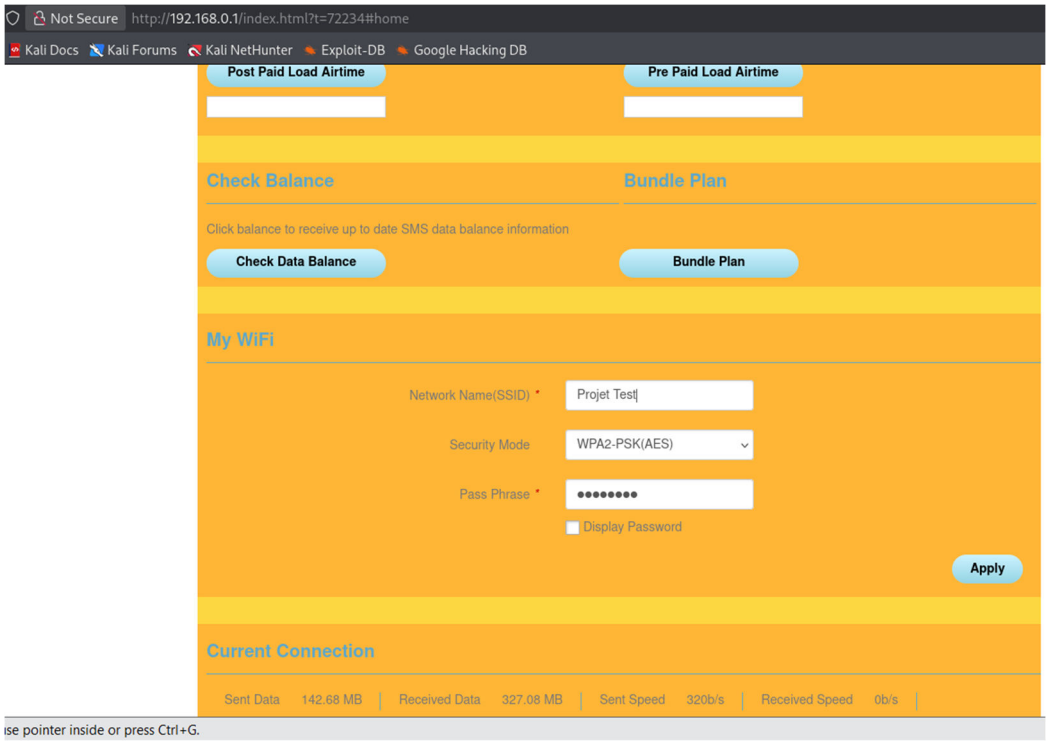


Figure 5: Authenticated admin dashboard, reached using default credentials — WPA2-PSK(AES) confirmed and SSID already renamed from the manufacturer default (see Section 5)

Recommendation: Change the default administrative password immediately to a strong, unique passphrase not reused from any other account.

4.2 Finding 2 — WPS Enabled (High)

Wi-Fi Protected Setup (WPS) was found enabled on the device. WPS PIN-based authentication is a long-standing weak point in consumer routers, independent of how strong the underlying WPA2 passphrase is.

Two attack paths apply here. Online PIN brute-forcing exploits a flaw in how WPS validates the 8-digit PIN — the access point checks the two halves separately, narrowing the real search space down to roughly 11,000 guesses rather than 10 million — implemented by tools such as Reaver and Bully. The offline Pixie Dust attack targets weak random-number generation in some devices' WPS implementations, allowing the PIN to be computed in seconds to minutes from a single captured exchange; Pixie Dust itself is an attack technique, not a tool, and pixiewps is the tool that implements it. Either path, once successful, hands over the actual WPA2 passphrase regardless of its strength.

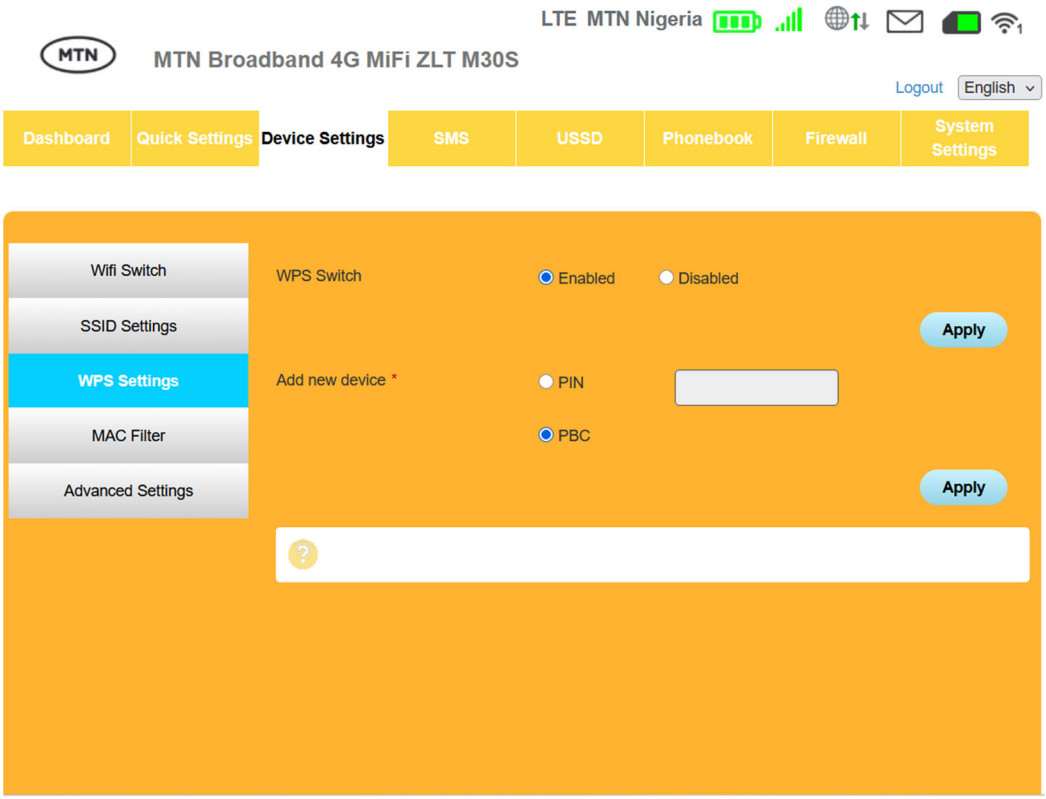


Figure 6: WPS setting shown in the MiFi device manager — WPS Switch: Enabled

Recommendation: Disable WPS in the MiFi's settings.

4.3 Finding 3 — Outdated / Vulnerable JavaScript Library: Underscore.js 1.3.1 (High)

OWASP ZAP's passive scanner (its Retire.js-based check) flagged the admin interface as loading Underscore.js version 1.3.1 — roughly a decade behind the current release (1.13.8 at the time of writing). Older Underscore.js versions are affected by a documented template-injection vulnerability in the library's_.template() function (CWE-1395, Use of Component with Known Vulnerabilities), which could allow script injection or cross-site scripting if untrusted input reaches that function. ZAP's alert confirms the vulnerable version is present on the page; it does not confirm that this specific admin interface actually feeds attacker-controlled input into that function, so live exploitability against this device was not independently tested.

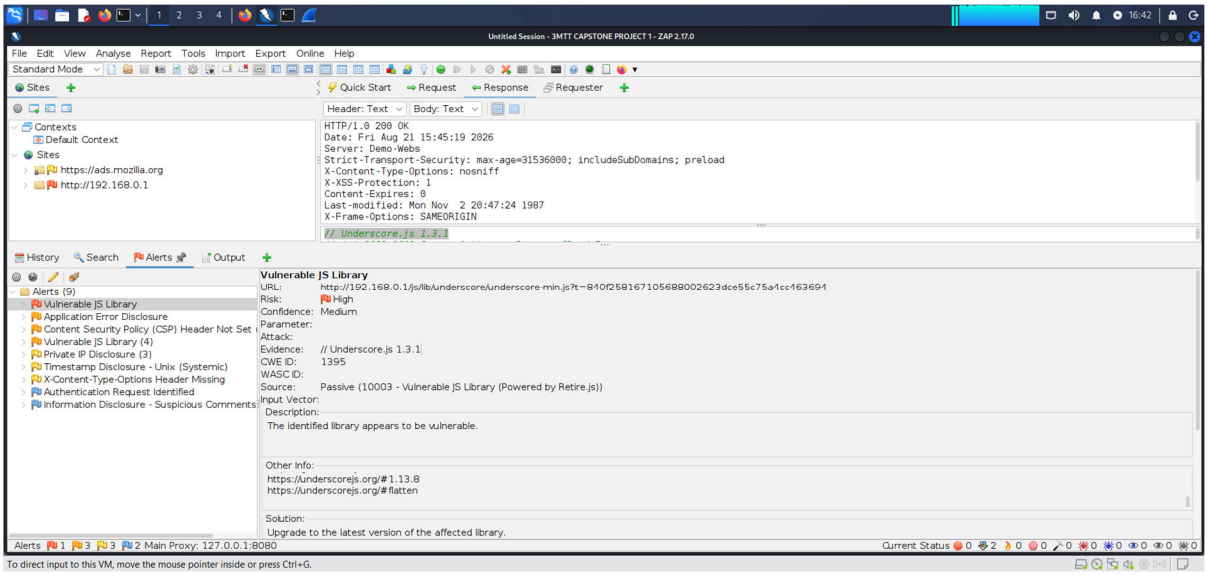


Figure 7: OWASP ZAP Alerts — Vulnerable JS Library (High), Underscore.js 1.3.1, detected via the Retire.js passive scan

Recommendation: Update or replace the bundled Underscore.js library with a current, patched release. Treat this as a supply-chain hygiene issue independent of confirmed exploitability — known vulnerabilities in an outdated version like this could allow script injection/XSS if the vulnerable code path is ever reachable.

4.4 Finding 4 — dnsmasq 2.80 (DNSpooq-Affected Range) (Medium–High)

Nmap identified dnsmasq 2.80 running on port 53. All dnsmasq versions prior to 2.83 are affected by the DNSpooq vulnerability set (CVE-2020-25681 through CVE-2020-25687), covering DNS cache-poisoning and buffer-overflow issues disclosed by JSOF in January 2021. Version 2.80 falls within this affected range. A subsequent full 65,535-port sweep (-p-) reconfirmed this banner via two independent NSE checks (dns-nsid and bind.version) and reconfirmed the port-80 admin server's “Demo-Webs” banner noted elsewhere in this report.

Evidence 1: Nmap service/version scan (MiFi)

```
53/tcp  open  domain    dnsmasq 2.80
80/tcp  open  http      (embedded admin web server)
443/tcp open  ssl/https?
|_ssl-date: TLS randomness does not represent time
```

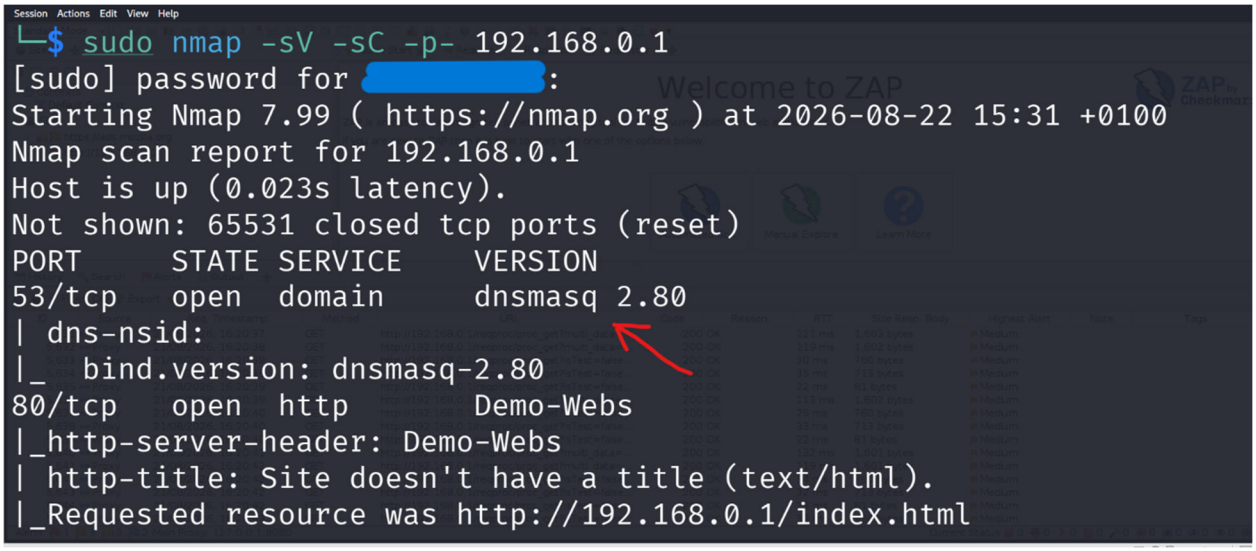


Figure 8: Full 65,535-port Nmap sweep (-sV -sC -p-) reconfirming dnsmasq 2.80 and the "Demo-Webs" HTTP banner

Recommendation: Update to a patched dnsmasq/firmware build. As established in Finding 5, no firmware update path currently exists for this model — this risk should therefore be treated as accepted/monitored rather than immediately fixable, reinforcing the importance of the compensating controls in Section 6.

4.5 Finding 5 — Admin Interface Served Over HTTP Only; No HTTPS or Firmware Upgrade Path (Medium)

The MiFi's web admin interface is served exclusively over plain HTTP, with no option in the settings to enable HTTPS/TLS. This was escalated to MTN customer care, who confirmed that no firmware upgrade exists for this model. Since the current firmware has no HTTPS/TLS option, and no update path exists to a firmware build that might add one, this is a de facto permanent limitation. Separately, firmware analysis found the same firmware build is shared across this entire device model line, meaning there is no newer in-model firmware to move to — the only path to a fix is a hardware upgrade to a different/newer model, which is recorded here as a longer-term recommendation.

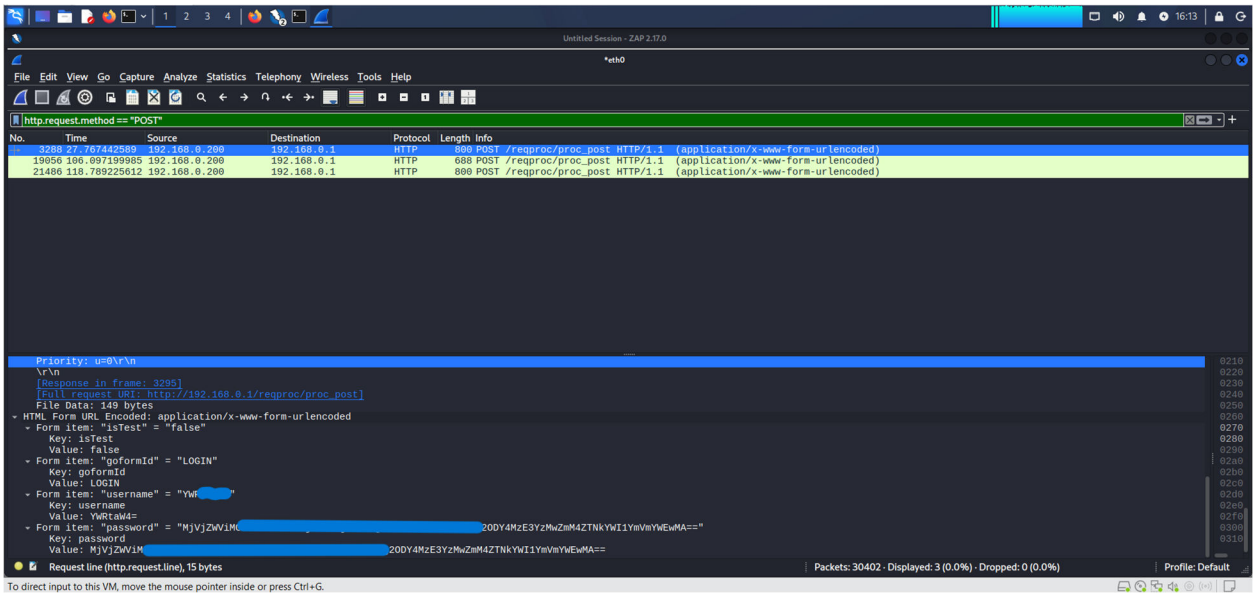


Figure 9: Browser address bar showing the admin panel served over http:// — "Not Secure", no padlock

Manual verification went beyond the address-bar observation above: Wireshark analysis of the login POST request (filtered with http.request.method == "POST") showed the username field base64-encoded — trivially reversible, decoding directly to the plaintext username (See Appendix B) — while the password field was submitted as a 64-character hex-formatted hash, base64-wrapped, that varied on each login attempt observed across three separate captures. This indicates the client-side JavaScript applies a nonce or challenge value before hashing rather than transmitting the raw password, which prevents a captured packet from simply being replayed to log in. This is a partial mitigation, not a substitute for TLS: the username remains exposed, and a response on this interface was observed carrying a Strict-Transport-Security header that has no real effect here, since browsers only honor HSTS when it is received over an actual HTTPS connection. General session traffic, cookies, and any other unencrypted fields on this HTTP-only interface remain fully readable to anyone on the same network segment.

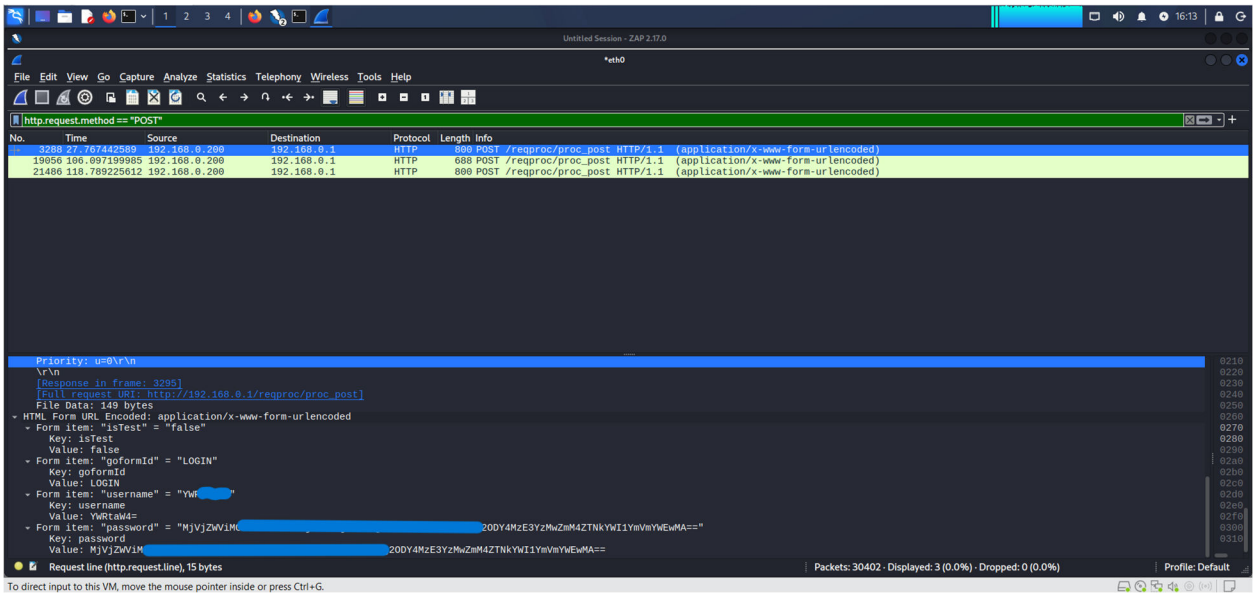


Figure 10: Wireshark capture of the login POST request — username base64-encoded (reversible); password submitted as a hash that varies per attempt

An attempt to decode the base64 encoded username was carried out on Kali terminal:

echo "username value" | base64 -d

The username was returned. See Appendix B.

Recommendation: No firmware-level fix is available for this device. Apply the compensating controls in Section 6 (LAN-only access, strong unique credentials, avoiding administration from untrusted networks, treating the connection as untrusted regardless of the password-hashing behaviour observed above). For long-term risk reduction, consider upgrading to a newer device model with TLS-capable firmware.

4.6 Finding 6 — Unauthenticated Information Disclosure (Low–Medium)

The MiFi's status/landing page discloses the list of connected devices and the device's battery level without requiring authentication. While this does not expose credentials directly, it does give any device on the network — authenticated or not — visibility into who else is connected, which is a minor reconnaissance aid for an attacker already on the same Wi-Fi.

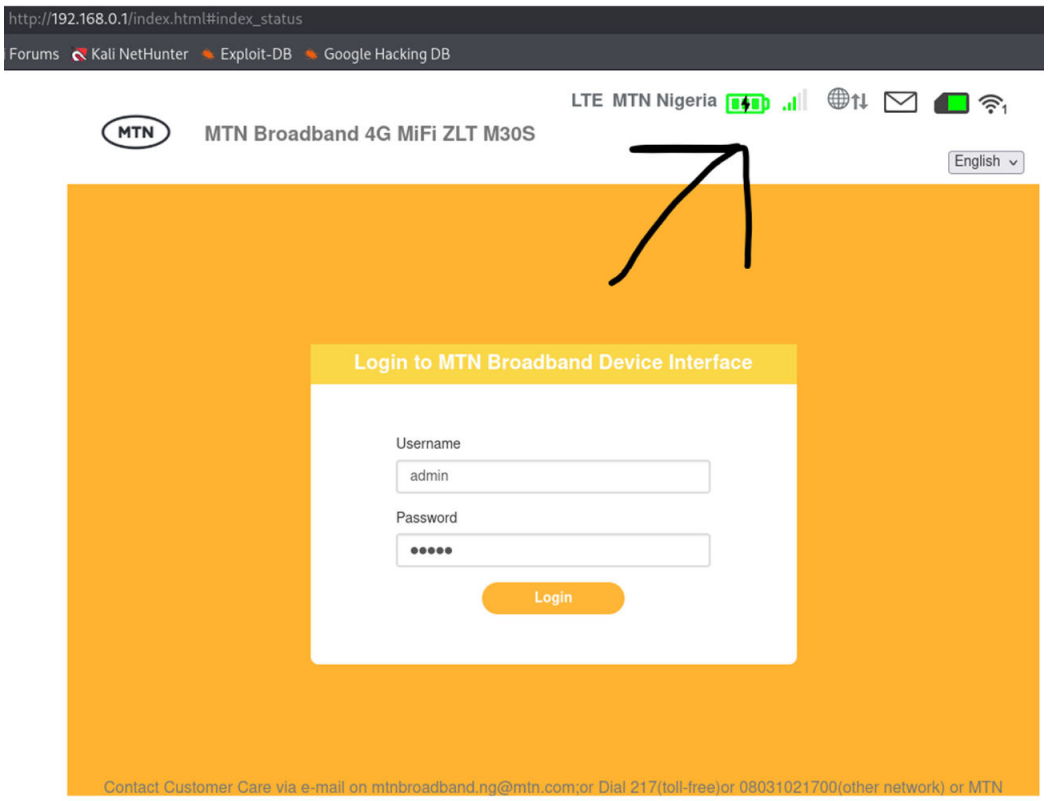


Figure 11: Unauthenticated status page — battery and connection-status indicators are visible in the page header before login

Recommendation: This is a platform-level limitation rather than a misconfiguration. Primary mitigation is keeping the device off untrusted networks and limiting who has the Wi-Fi passphrase.

4.7 Finding 7 — Slowloris DoS Heuristic Flag (Medium, Unconfirmed)

Nmap's http-slowloris-check script flagged the MiFi's embedded web server as "likely vulnerable" to a Slowloris-style denial-of-service (CVE-2007-6750), where many partial HTTP connections are held open to exhaust server resources. This is a heuristic result based on server behaviour, not a confirmed live exploit — an active Slowloris test was deliberately not run against the device, since it could hang the assessor's only MiFi.

Evidence 2: Nmap --script vuln excerpt

```
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|     Disclosure date: 2009-09-17
```

Recommendation: Record as a scanner-flagged, unconfirmed risk. No action required beyond awareness; do not run an active resource-exhaustion test against a single production device.

Triage Note — Discounted / Not-Applicable Automated Findings

- http-vuln-cve2010-0738 flagged /jmx-console/ as accessible without authentication. This check is specific to JBoss Application Server, which this device does not run. Manual verification (comparing the response to a known-nonexistent path) returned identical output for both, confirming the device returns a catch-all HTTP 200 for any path — a false positive, not a real finding.
- http-vuln-cve2014-3704 (Drupal), http-aspnet-debug (ASP.NET), and http-vuln-cve2017-1001000 (WordPress) all returned script execution errors rather than a positive or negative result. These checks target technology stacks this embedded device does not run and are recorded as not applicable rather than "tested, not vulnerable."
- http-dombased-xss returned "Couldn't find any DOM based XSS" — this is a genuine tested-and-clean result and is carried into Section 5 as a positive observation. This is distinct from CSRF and stored XSS, neither of which is covered by Nmap's default vulnerability scripts, and distinct from Finding 3's vulnerable-library flag, which is a component-version issue rather than a confirmed exploitable XSS on this device.

4.8 Additional Observation (Non-Target) — Host Machine Network Exposure (Informational)

For completeness, the network scan phase also profiled the host machine and the Kali VM itself, not just the MiFi. These are environment observations rather than target findings, but are recorded here since they surfaced from the same testing activity.

Evidence 3: Nmap scan of the host machine

```
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE
902/tcp  open  iss-realsecure
912/tcp  open  apex-mesh
5357/tcp open  wsdapi
```

Ports 902 and 912 are not actually the legacy IDS/monitoring products Nmap's service-name database labels them as — they are VMware Workstation's own vmware-authd/hostd ports, reachable here over the bridged Wi-Fi interface rather than restricted to localhost. Port 5357 (wsdapi) is standard Windows network-discovery. Neither is a MiFi vulnerability, but it is worth firewalling VMware's authentication ports to localhost on the host machine when they are not actively needed on the LAN.

Evidence 4: Nmap self-scan of the Kali VM

```
All 1000 scanned ports on (VM) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
```

The Kali VM itself exposed no listening services to the network — a clean result carried forward into Section 5.

5. Positive Security Observations

Not every result of this assessment was a weakness. The following controls were found correctly configured, or were configured during testing, and are recorded here as evidence of a reasonably managed device baseline.

- WPA2-PSK (AES) encryption in use — not the deprecated WEP or an open network (see Figure 5).
- UPnP disabled.
- Account lockout enforced on the admin login after repeated failed attempts, tracked per source IP with a reset based on device reboot (see Section 2.5 and the figure below).
- MAC address blacklisting available and identified as a usable control for restricting device access.
- SSID changed from the manufacturer's default to a non-identifying name, reducing casual identification of the device brand/type by nearby users (see Figure 5).
- Data usage cap re-enabled with an SMS alert at 50% usage, providing an early warning of unexpected data consumption (e.g. from an unauthorized connected device — see the figure below).
- Connected-device list reviewed and pruned from 8 to 4 devices, removing unrecognized or unnecessary entries.
- No DOM-based XSS found on the admin interface (Nmap http-dombased-xss, tested and clean — see Section 4.7 triage note).
- The Kali VM testing platform itself exposed no listening network services (Nmap self-scan: 1000/1000 ports filtered — see Section 4.8).
- The admin login password is hashed client-side with a value that varies per attempt rather than transmitted as raw plaintext, discovered via manual Wireshark verification (Section 4.5) — a partial mitigation on an otherwise unencrypted interface.

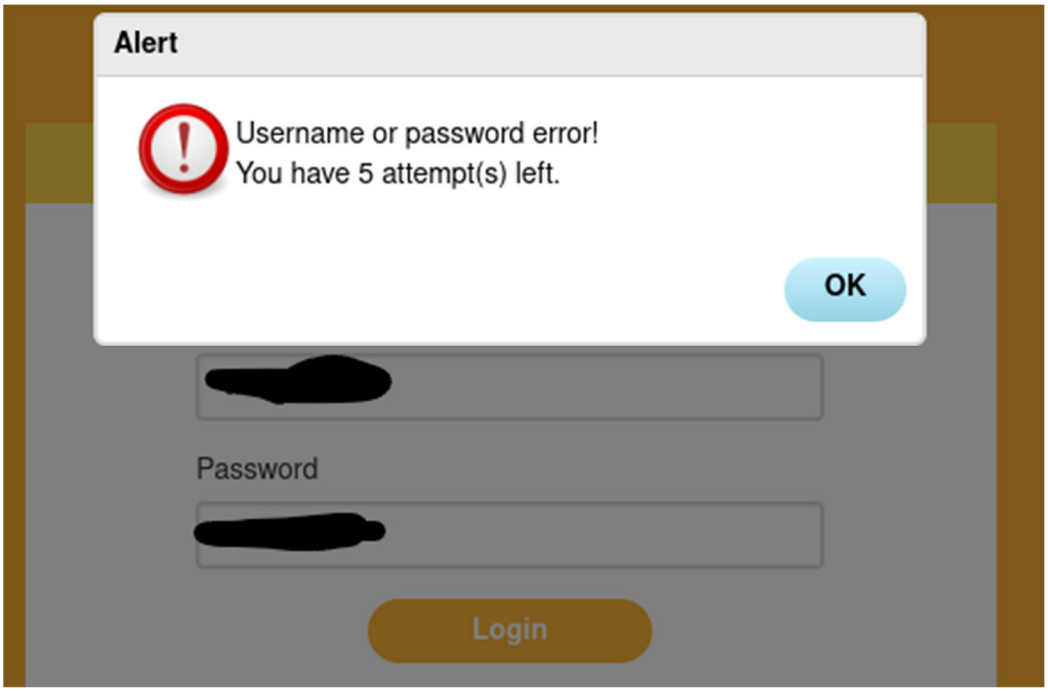


Figure 12: Account lockout enforced after repeated failed login attempts

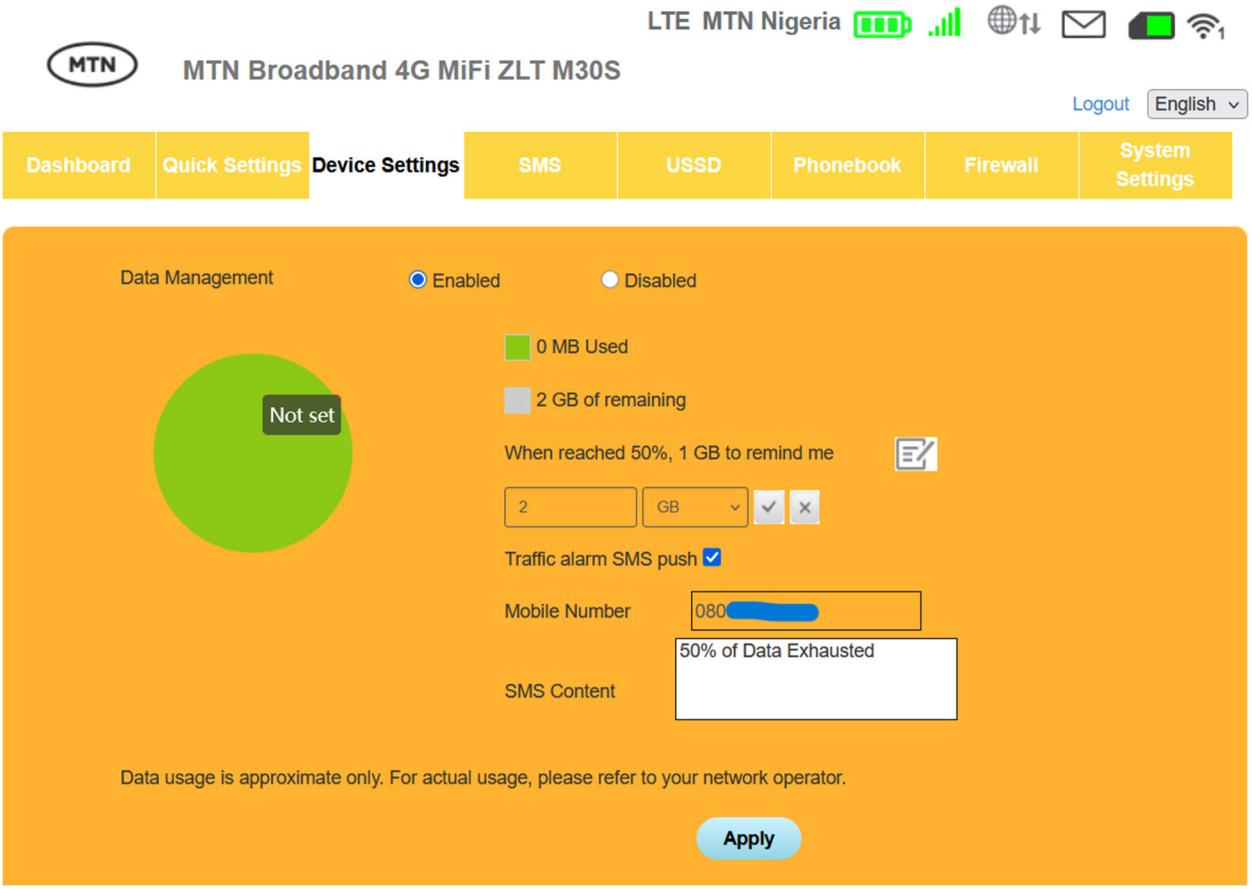


Figure 13: Data-usage cap re-enabled with an SMS traffic alarm at 50% usage

6. Remediation & Hardening Recommendations

Prioritized action list, consolidating Section 4:

- Immediate (Critical/High): Change the default admin password to a strong, unique passphrase. Disable WPS. Update or replace the vulnerable Underscore.js component (currently 1.3.1) flagged by ZAP with a current, patched release (Finding 3).
- Compensating controls for the unfixable HTTP-only admin interface: keep administration to the local Wi-Fi network only, never administer the device from an untrusted network, and use a password manager rather than a memorized/reused password. Note: the login password is hashed client-side with a per-attempt varying value before submission, so it is not sent as raw plaintext — but the username and the interface's general session traffic still transit unencrypted, so the connection should still be treated as untrusted.
- Monitor rather than patch: the dnsmasq/DNSpooq exposure and the Slowloris heuristic flag cannot currently be fixed at the firmware level; mitigate by limiting who has Wi-Fi access and keeping an eye on connected-device counts.
- Longer term: consider a hardware upgrade to a MiFi/router model with an actively maintained firmware branch and TLS-capable admin interface.
- Already in place: WPA2-PSK (AES), UPnP disabled, account lockout, data-usage alerting, a renamed SSID, and a pruned connected-device list — maintain these going forward.

7. Conclusion

This assessment found a personal MTN MiFi device with a broadly typical consumer-grade risk profile: a critical credential-hygiene issue, a legacy WPS exposure, an outdated third-party JavaScript component with a known vulnerability class, and a small set of firmware-level weaknesses that cannot currently be remediated at the vendor's own admission. None of the findings required advanced exploitation to identify, which is itself notable — the most impactful issues here (default credentials, WPS, the vulnerable library) are also the cheapest to fix and should be addressed first. Manual packet-level verification of the login flow also uncovered a nuance that automated scanning alone would have missed: the admin password is hashed client-side with a per-attempt varying value rather than sent as raw plaintext — a partial mitigation that does not substitute for the missing TLS, but is worth stating precisely rather than overclaiming. Where the underlying platform cannot be fixed (HTTP-only admin, frozen firmware), the recommended compensating controls meaningfully reduce practical risk even though they do not eliminate it outright. Several controls were already well configured, indicating a device baseline that, with the immediate fixes in Section 6 applied, would represent a reasonable security posture for its intended personal-use context.

Appendix A: Tools & Versions

- Kali Linux (VMware Workstation, bridged network adapter)
- Nmap — host discovery, service/version scan (-sV -sC), vulnerability scan (--script vuln), full-port sweep (-p-)
- OWASP ZAP (Community Edition) — add-ons maintained on the Release update channel, downloaded via ZAP's official marketplace and checksum-verified (SHA-256) against the zaproxy project's own manifest; passive scanning included the "Vulnerable JS Library (Powered by Retire.js)" check used for Finding 3.
- Wireshark — traffic capture and filtering (http.request.method == "POST", tls, DNS)

Appendix B: Username Decoded



Figure 14: Decoded base64 encoded Username

Appendix C: References

- JSOF. "DNSpooq — Seven vulnerabilities disclosed in dnsmasq." January 2021. jsof-tech.com/disclosures/dnspooq
- NVD. CVE-2020-25681, CVE-2020-25682, CVE-2020-25683, CVE-2020-25684, CVE-2020-25685, CVE-2020-25686, CVE-2020-25687 (dnsmasq / DNSpooq). nvd.nist.gov
- NVD. CVE-2007-6750 — Slowloris HTTP Denial of Service. nvd.nist.gov
- NVD. CVE-2021-23358 — Underscore.js template-injection vulnerability. nvd.nist.gov
- RetireJS Project. Vulnerable JavaScript library detection database, used by OWASP ZAP's passive scanner. retirejs.github.io/retire.js
- MITRE. CWE-1395 — Dependency on Vulnerable Third-Party Component. cwe.mitre.org/data/definitions/1395.html
- Bongard, Dominique. "Offline Bruteforce Attack on WiFi Protected Setup" (the Pixie Dust attack). PasswordsCon, 2014.
- pixiewps — Pixie Dust attack implementation. github.com/wiire-a/pixiewps
- Reaver — WPS PIN brute-force implementation. github.com/t6x/reaver-wps-fork-t6x
- Bully — WPS PIN brute-force / Pixie Dust implementation. github.com/aanarchyy/bully
- OWASP ZAP documentation. zaproxy.org
- Nmap Reference Guide. nmap.org/book
- Wireshark documentation. wireshark.org/docs